

系统加固之Linux安全加固

作者: z释然z

原文链接: <https://mp.weixin.qq.com/s/cj2IpePACewH2wqXFgKTDw>

本文由 干货集中营 收集整理: <http://www.nmd5.com/test/index.php>



Linux系统基本操作

文件结构图及关键文件功能介绍

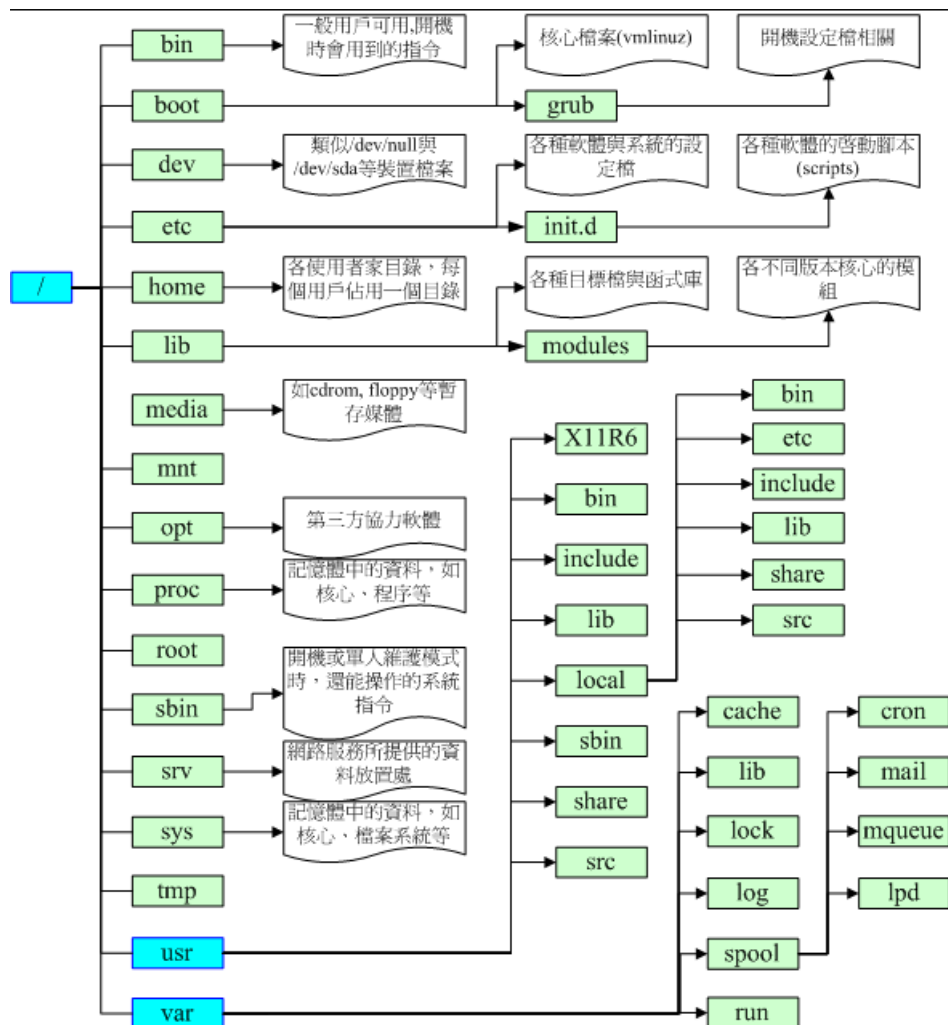
Linux文件结构

```

[root@localhost /]# ls
bin      dev      lib      media    net      root      srv      usr
boot     etc      lib64    misc     opt      sbin      sys      var
chroot_list  home    lost+found  mnt      proc     selinux   tmp
[root@localhost /]# ll
total 106
dr-xr-xr-x.  2 root root  4096 Jun 16 06:35 bin
dr-xr-xr-x.  5 root root  1024 Jun 16 05:15 boot
-rw-r--r--.  1 root root    3 Jun 16 07:37 chroot_list
drwxr-xr-x  18 root root  3740 Jun 28 02:30 dev
drwxr-xr-x. 118 root root 12288 Jun 28 03:30 etc
drwxr-xr-x.  4 root root  4096 Jun 16 07:50 home
dr-xr-xr-x. 11 root root  4096 Jun 16 05:10 lib
dr-xr-xr-x.  9 root root 12288 Jun 16 06:35 lib64
drwx-----.  2 root root 16384 Jun 16 05:01 lost+found
drwxr-xr-x.  3 root root  4096 Jun 28 02:18 media
drwxr-xr-x.  2 root root    0 Jun 28 02:30 misc
drwxr-xr-x.  2 root root  4096 Sep 23 2011 mnt
drwxr-xr-x.  2 root root    0 Jun 28 02:30 net
drwxr-xr-x.  3 root root  4096 Jun 16 05:13 opt
dr-xr-xr-x 125 root root    0 Jun 28 02:30 proc
dr-xr-x---. 25 root root  4096 Jun 28 02:39 root
dr-xr-xr-x.  2 root root 12288 Jun 16 06:35 sbin
drwxr-xr-x.  2 root root  4096 Jun 16 05:03 selinux
drwxr-xr-x.  2 root root  4096 Sep 23 2011 srv
drwxr-xr-x  13 root root    0 Jun 28 02:30 sys
drwxrwxrwt. 10 root root  4096 Jun 28 03:30 tmp
drwxr-xr-x. 13 root root  4096 Jun 16 05:03 usr
drwxr-xr-x. 24 root root  4096 Jun 16 08:25 var
[root@localhost /]#

```

Linux文件结构图



二级目录

目录

功能

/bin	放置的是在单人维护模式下能被操作的指令，在/bin底下的指令可以被root与一般账号所使用
/boot	这个目录只要在放置开机会使用到的文件，包括 Linux核心文件以及开机选单与开机所需配置的文件等等
/dev	在Linux系统上，任何装置与接口设备都是以文件的形态存在于这个目录当中的
/etc	系统主要的配置文件几乎都放在这个目录内，例如人员账号密码各种服务的启动档，系统变量配置等
/home	这个是系统默认的用户家目录（home directory）
/lib	/lib放置的则是在开机时会用到的函式库，以及在/lib或/sbin底下的指令会呼叫的函式库

/media	/media底下放置的是可以移出的装置，包括软盘、光盘、DVD等等装置都挂载于此
/opt	给第三方协议软件放置的目录
/root	系统管理员（root）的家目录
/sbin	放置/sbin底下的为开机过程中所需要的，里面包括了开机、修复、还原系统所需的指令。
/srv	srv可视为[service]的缩写，是一些网络服务启动之后，这些服务所需要取用的数据目录
/tmp	这是让一般使用者或是正在执行的程序暂时放置文件的地方

文件

目录	功能
/etc/passwd	记录系统本地用户的属性信息，如UId,Gid,家目录等信息
/etc/shadow	存放用户的口令等信息，只有系统管理员用户能查看
/etc/pam.d/system-auth	账户安全配置文件
/etc/login.defs	设置用户账户限制的配置文件，对root用户无效
/etc/securetty	网络配置文件
/etc/pam.d/su	su命令配置
/etc/hosts.allow /etc/hosts.deny	允许/拒接某网段远程连接到主机
/etc/profile	保存Linux全局环境变量信息，如umask,bash历史命令设置

账号和权限

系统用户

超级管理员 uid=0

系统默认用户 系统程序使用，从不登录

新建普通用户 uid大于500

```
[root@localhost /]# cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
adm:x:3:4:adm:/var/adm:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/spool/mail:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucp:/sbin/nologin
operator:x:11:0:operator:/root:/sbin/nologin
games:x:12:100:games:/usr/games:/sbin/nologin
gopher:x:13:30:gopher:/var/gopher:/sbin/nologin
ftp:x:14:50:FTP User:/var/ftp:/sbin/nologin
nobody:x:99:99:Nobody:/:/sbin/nologin
dbus:x:81:81:System message bus:/:/sbin/nologin
usbmuxd:x:113:113:usbmuxd user:/:/sbin/nologin
vcsa:x:69:69:virtual console memory owner:/dev:/sbin/nologin
rpc:x:32:32:Rpcbind Daemon:/var/cache/rpcbind:/sbin/nologin
rtkit:x:499:497:RealtimeKit:/proc:/sbin/nologin
avahi-autoipd:x:170:170:Avahi IPv4LL Stack:/var/lib/avahi-autoipd:/sbin/nologin
abrt:x:173:173:/:/etc/abrt:/sbin/nologin
rpcuser:x:29:29:RPC Service User:/var/lib/nfs:/sbin/nologin
nfsnobody:x:65534:65534:Anonymous NFS User:/var/lib/nfs:/sbin/nologin
haldaemon:x:68:68:HAL daemon:/:/sbin/nologin
gdm:x:42:42:/:/var/lib/gdm:/sbin/nologin
ntp:x:38:38:/:etc/ntp:/sbin/nologin
apache:x:48:48:Apache:/var/www:/sbin/nologin
saslauth:x:498:76:Saslauthd user:/var/empty/saslauth:/sbin/nologin
postfix:x:89:89:/:var/spool/postfix:/sbin/nologin
pulse:x:497:496:PulseAudio System Daemon:/var/run/pulse:/sbin/nologin
sshd:x:74:74:Privilege-separated SSH:/var/empty/sshd:/sbin/nologin
tcpdump:x:72:72:/:/sbin/nologin
sr:x:500:500:/:home/sr:/bin/bash
ghw:x:501:501:/:home/ghw:/bin/bash
named:x:25:25:Named:/var/named:/sbin/nologin
[root@localhost /]#
```

```
[root@svr5 ~]# head -1 /etc/passwd  
root:x:0:0:root:/root:/bin/bash
```



字段1：用户帐号的名称
字段2：密码字符串或占位符 x
字段3：用户帐号的UID号
字段4：所属基本组的GID号
字段5：用户全名
字段6：宿主目录
字段7：登录Shell程序的路径


```
[root@svr5 ~]# head -1 /etc/shadow
```

```
root:$1$SmIKPNho$qNq.. ..OGBSmvil6b1:15908:0:99999:7:::
```

字段1：用户帐号的名称

字段2：加密后的密码字符串

字段3：上次修改密码的时间

字段4：密码的最短有效天数，默认0

字段5：密码的最长有效天数，默认99999

字段6：密码过期前的警告天数，默认7

字段7：密码过期后多少天禁用此用户账号

字段8：帐号失效时间，默认值为空

字段9：保留字段（未使用）

添加用户：

`useradd <用户名>`

删除用户：

`userdel [-r][-f] <用户名>`

锁定/解锁用户：

`passwd -l <用户名>`

`passwd -u <用户名>`

用户属性：

`usermod -L <用户名>` 锁定用户

`usermod -U <用户名>` 解锁用户

查看当前用户

`id`

权限管理

解析文件权限

- 执行 `ls -l ...` 命令查看

- 输出信息包括7个字段

```
[root@svr5 ~]# ls -ld /etc/passwd /boot
drwxr-xr-x 4 root root 1024 07-10 17:22 /boot
-rw-r--r-- 1 root root 1715 08-24 11:42 /etc/passwd
```

权限位 硬链接数 属主 属组 大小 最后修改时间 文件/目录名称

权限和归属

- 访问权限
 - 读取：允许查看内容-**read**
 - 写入：允许修改内容-**write**
 - 可执行：允许运行和切换-**execute**
- 归属关系
 - 所有者：拥有此文件/目录的用户-**user**
 - 所属组：拥有此文件/目录的组-**group**
 - 其他用户：除所有者、所属组以外的用户-**other**
 - 所有用户：以上三类归属合称-**all**

共同决定最终权限

文件系统安全

查看权限：`ls -l`

```
[root@localhost /]# ls -l
```

```
dr-xr-xr-x.  2 root root  4096 Jun 16 06:35 bin
```

修改权限：

chmod

```
[root@localhost ~]# chmod 777 test
```

```
drwxrwxrwx  2 root root  4096 Jun 28 05:08 test
```

chown

```
[root@localhost ~]# chown 123:123 test
```

```
drwxrwxrwx  2 123  123  4096 Jun 28 05:08 test
```

chgrp

```
[root@localhost ~]# chgrp root test
```

```
drwxrwxrwx  2 123  root  4096 Jun 28 05:08 test
```

设置合理的初始文件权限

很奇妙的UMASK:

```
[root@localhost ~]# umask  
0022
```

umask值为0022所对应的默认文件和文件夹创建的缺省权限分别为644和755

文件夹其权限规则为: 777-022=755

文件其权限规则为: 777-111-022=644 (因为文件默认没有执行权限)

修改UMASK值:

1、直接在命令行下 umask xxx(重启后消失)

2、修改/etc/profile中设置的umask值

```
[root@localhost ~]# umask 027  
[root@localhost ~]# mkdir mask  
[root@localhost ~]# ls -l
```

```
drwxr-x---  2 root root  4096 Jun 28 06:01 mask
```

系统加固

锁定系统中多余的自建账号

执行命令

```
#cat /etc/passwd  
#cat /etc/shadow
```

查看账户、口令文件，与系统管理员确认不必要的账号。对于一些保留的系统伪帐户如：bin, sys,

adm, uucp, lp, nuucp, hpdb, www, daemon等可根据需要锁定登陆。

加固方法:

使用命令passwd -l <用户名>锁定不必要的账号。

使用命令passwd -u <用户名>解锁需要恢复的账号。

检查shadow中空口令账号

检查方法:

```
[root@localhost ~]# awk -F ":" '($2=="!!") {print $1}' /etc/shadow
```

```
[root@localhost ~]# awk -F ":" '($2== "!!") {print $1}' /etc/shadow
dbus
usbmuxd
vcsa
rpc
rtkit
avahi-autoipd
abrt
rpcuser
nfsnobody
haldaemon
gdm
ntp
apache
ssslauth
postfix
pulse
sshd
tcpdump
named
123
mysql
1234
12345
456
451
[root@localhost ~]#
```

加固方法：

使用命令 `passwd -l <用户名>` 锁定不必要的账号

使用命令 `passwd -u <用户名>` 解锁需要恢复的账号

使用命令 `passwd <用户名>` 为用户设置密码

设置系统密码策略

执行命令查看密码策略设置

```
[root@localhost ~]# cat /etc/login.defs | grep PASS
# PASS_MAX_DAYS Maximum number of days a password may be used.
# PASS_MIN_DAYS Minimum number of days allowed between password changes.
# PASS_MIN_LEN Minimum acceptable password length.
# PASS_WARN_AGE Number of days warning given before a password expires.
PASS_MAX_DAYS 99999
PASS_MIN_DAYS 0
PASS_MIN_LEN 5
PASS_WARN_AGE 7
[root@localhost ~]#
```

加固方法：

#vi /etc/login.defs 修改配置文件

PASS_MAX_DAYS	90	#用户的密码最长使用天数
PASS_MIN_DAYS	0	#两次修改密码的最小时间间隔
PASS_MIN_LEN	7	#密码的最小长度
PASS_WARN_AGE	9	#密码过期前多少天开始提示

禁用root之外的超级用户

检测方法：

```
awk -F ":" '($3=="0"){print $1}' /etc/passwd
```

加固方法：

passwd -l <用户名>

```
[root@localhost ~]# awk -F ":" '($3=="0"){print $1}' /etc/passwd
root
[root@localhost ~]#
```

限制能够su为root的用户

查看是否有 auth required /libsecurity/pam_what.so 这样的配置条目

```
[root@localhost ~]# cat /etc/pam.d/su
#%PAM-1.0
auth        sufficient    pam_rootok.so
# Uncomment the following line to implicitly trust users in the "wheel" group.
#auth       sufficient    pam_wheel.so trust use_uid
# Uncomment the following line to require a user to be in the "wheel" group.
#auth       required      pam_wheel.so use_uid
auth        include       system-auth
account     sufficient    pam_succeed_if.so uid = 0 use_uid quiet
```

加固方法:

在头部添加:

```
auth required /lib/security/pam_wheel.so group=wheel
这样, 只有wheel组的用户可以su到root
```

```
#usermod -G10 test 将test用户加入到wheel组
```

重要文件加上不可改变属性

把重要文件加上不可改变属性

```
[root@localhost ~]# chattr +i /etc/passwd
[root@localhost ~]# chattr +i /etc/shadow
[root@localhost ~]# chattr +i /etc/gshadow
[root@localhost ~]# chattr +i /etc/group
[root@localhost ~]# chattr +i /etc/httpd/
```

Umask安全

```
[root@localhost ~]# umask
0022
[root@localhost ~]#
```

第一个0代表suid 丢弃的权限;

第二个0代表本文件/目录所有者什么权限都没丢弃

第三个2代表本文件/目录的用户组丢弃了w权限

第四个2代表本文件/目录的其他用户能使用的权限只有有r和x

实际权限=7777-0022

设置合理的umask权限

umask 0022

SSH安全:

禁止root用户进行远程登陆

检查方法:

```
[root@localhost ~]# cat /etc/ssh/sshd_config | grep PermitRootLogin
```

加固方法:

```
[root@localhost ~]# vi /etc/ssh/sshd_config
```

```
PermitRootLogin no
```

更改服务端口:

```
[root@localhost ~]# vi /etc/ssh/sshd_config
```

```
Port 2222
```

屏蔽SSH登陆banner信息

屏蔽SSH登录banner信息

检查方法:

```
# cat /etc/ssh/sshd_config
```

查看文件中是否存在banner字段, 或banner字段为NONE

```
# cat /etc/motd
```

查看文件内容, 该处内容作为banner信息显示给登录用户

加固方法:

```
#vim /etc/ssh/sshd_config
```

添加:

```
banner NONE
```

```
#vim /etc/motd
```

删除全部内容或更新成自己想要添加的内容

仅允许SSH协议版本2

有两个SSH协议版本，仅使用SSH协议版本2会更安全，SSH协议版本1有安全问题，包括中间人攻击（man-in-the-middle）和注入（insertion）攻击。

编辑/etc/ssh/sshd_config文件并查找下面这样的行：

Protocol 2,1

修改为

Protocol 2

```
[root@localhost ~]# cat /etc/ssh/sshd_config | grep Protocol
Protocol 2
[root@localhost ~]#
```

防止误使用Ctrl+Alt+Del重启系统

检查方法：

```
#cat /etc/inittab |grep ctrlaltdel 查看输出行是否被注释
ca::ctrlaltdel:/sbin/shutdown -t3 -r now
```

加固方法：

```
#vim /etc/inittab
在行开否添加注释符号“#”
#ca::ctrlaltdel:/sbin/shutdown -t3 -r now
```

设置账号锁定登录失败锁定次数、锁定时间

检查方法：

```
# cat /etc/pam.d/system-auth|grep auth 查看有无auth required pam_tally.so 条目的设置
```

加固方法：

```
#vi /etc/pam.d/system-auth
auth required pam_tally.so oneer=filad deny=6 unlock_time=300 设置为密码连续错误6次，锁定时间300
秒
```

解锁用户：

```
faillog -u <用户名> -r
```

修改账号TMOUT值，设置自动注销时间

检查方法：

```
cat /etc/profile | grep TMOUT
```

加固方法：

```
vim /etc/profile
```

增加

TMOUT=600 无操作600秒后自动退出

```
[root@localhost ~]# cat /etc/profile | grep TMOUT
TMOUT = 600
[root@localhost ~]#
```

设置BASH保留历史命令的条目

检查方法:

```
cat /etc/profile | grep HISTSIZE
```

加固方法:

```
vim /etc/profile
```

修改HISTSIZE=5即保留最新执行的5条命令

```
/etc/profile 602, 1007c written
[root@localhost ~]# cat /etc/profile | grep HISTSIZE
HISTSIZE=5
```

设置注销时删除命令记录

检查方法:

```
cat /etc/skel/.bash_logout 增加如下行
```

```
rm -f $HOME/.bash_history
```

这样，系统中的所有用户注销时都会删除其命令记录，如果只需要针对某个特定用户，，如root用户进行设置，则可只在该用户的主目录下修改\$HOME/.bash_history文件增加相同的一行即可。

设置系统日志策略配置文件

日志的主要用途是 系统审计、监测追踪和分析。为了保证 Linux 系统正常运行、准确解决遇到的各种样统问题，认真地读取日志文件是管理员的一项非常重要任务。

UNIX/ Linux 采用了syslog 工具来实现此功能，如果配置正确的 话，所有在主机上发生的事情都会被记录下来不管是好还是坏的 。

检查方法:

```
cat /etc/profile | grep HISTSIZE
```

```
[root@localhost ~]# ps -aef | grep syslog
root      1498      1  0 02:30 ?        00:00:00 /sbin/rsyslogd -i /var/run/syslogd
c 5
gdm       2210      1  0 02:30 ?        00:00:00 /usr/bin/pulseaudio --start --log-
=syslog
root      4385    4164  0 10:23 pts/0    00:00:00 grep syslog
[root@localhost ~]#
```

确定syslog服务是否启用

```
[root@localhost ~]# cat /etc/rsyslog.conf
```

查看syslogd的配置，并确认日志文件是否存在

系统日志 (默认) /var/log/messages
cron日志 (默认) /var/log/cron
安全日志 (默认) /var/log/secure

阻止系统响应任何从外部/内部来的ping请求

加固方法:

echo 1 >/proc/sys/net/ipv4/icmp_echo_ignore_all

```
[root@localhost ~]#
[root@localhost ~]# echo 1 >/proc/sys/net/ipv4/icmp_echo_ignore_all
[root@localhost ~]# ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0C:29:15:A6:B4
          inet addr:192.168.10.100  Bcast:192.168.10.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe15:a6b4/64 Scope:Link
```

```
C:\Windows\system32\cmd.exe
Microsoft Windows [版本 10.0.17763.805]
(c) 2018 Microsoft Corporation。保留所有权利。

C:\Users\94251>ping 192.168.10.100

正在 Ping 192.168.10.100 具有 32 字节的数据:
请求超时。
请求超时。
请求超时。
请求超时。

192.168.10.100 的 Ping 统计信息:
    数据包: 已发送 = 4, 已接收 = 0, 丢失 = 4 (100% 丢失),
```

知识星球



星主：释然

网事如烟



长按扫码预览社群内容
和星主关系更近一步

合伙运营

更多精彩推荐，请关注我们



转发是最大的鼓励

生活不止眼前的苟且，

还有课本里的诗和到不了的远方！